

# CyberQuery AI

Enterprise SOC Investigation Assistant with Two-Gate Governance & Query Safety Architecture

## 1. Executive Summary

**CyberQuery AI** is an enterprise-grade AI-powered Security Operations Center (SOC) investigation platform. It enables security analysts to query complex security telemetry using plain natural-language questions without needing to manually construct vendor-specific SIEM queries (SQL, KQL, SPL). The system operates on the core security rule that **LLMs never execute unvalidated code or queries directly** against production data stores. Instead, CyberQuery AI enforces a **Two-Gate Safety Architecture** and a real-time **Governance & Controls Layer** to guarantee that invalid, out-of-scope, or mutating queries are halted before reaching the database.

### Key Value Proposition

| Problem Area                                                                                                                           | CyberQuery AI Technical Solution                                                                                                                      |
|----------------------------------------------------------------------------------------------------------------------------------------|-------------------------------------------------------------------------------------------------------------------------------------------------------|
| <b>3:00 AM SOC Bottleneck</b><br>Analysts spend critical minutes writing complex SPL/KQL syntax during high-stress security incidents. | <b>Natural Language to Query DSL</b><br>Translates plain English questions into structured Investigation Intent DSL in under 200ms.                   |
| <b>AI Hallucination Hazard</b><br>Direct LLM query execution can cause hallucinated fields, database exhaustion, or data loss.         | <b>Two-Gate Safety Architecture</b><br>Gate 1 validates intent; Gate 2 enforces schema whitelists, read-only permissions, and time caps.              |
| <b>Uncontrolled AI Access</b><br>Lack of administrative boundaries over what AI can query.                                             | <b>Governance &amp; Controls Module</b><br>SOC Admins configure maximum time ranges, result caps, allowed fields, and scenario permissions with RBAC. |

## 2. Technical System Architecture

CyberQuery AI decouples intent parsing, query generation, safety validation, data access, and threat analysis into a robust pipeline:





### 3. Two-Gate Safety & Governance Enforcement

#### Gate 1 — Intent Validation Gate

Evaluates whether the user's natural language input represents a valid SOC security investigation and verifies that the scenario is enabled by SOC Admin in Governance policy.

- **Garbage Input ('dfhj')**: Caught at Gate 1. Status: INTENT\_BLOCKED. Query Generation: BLOCKED. SIEM Database: 0 Queries Run.
- **Non-Security Questions ('What is the weather today?')**: Caught at Gate 1. Status: INTENT\_BLOCKED.
- **Disabled Scenario**: If SOC Admin disables DNS Tunneling, DNS queries are blocked at Gate 1.

#### Gate 2 — Query Safety Gate

Validates the generated SQL for schema whitelist compliance, read-only permissions, mandatory time range scopes, and maximum result limits.

- **Max Time Range Enforcement**: If Admin sets a 24-hour max limit, a requested 7-day query is blocked at Gate 2 with 'Governance Violation: Requested 7-day range exceeds Governance limit of 24 hours'.
- **Read-Only Execution**: Blocks all DDL/mutation keywords (DROP, DELETE, UPDATE, INSERT, ALTER, TRUNCATE, CREATE, GRANT, REVOKE).
- **Schema Field Whitelist**: Only whitelisted fields (timestamp, username, source\_ip, process, etc.) are allowed.

### 4. Core Investigation Scenarios & MITRE Mapping

| Scenario       | MITRE Technique      | Risk Level    | Evidence & Detection Rule                                                                                  |
|----------------|----------------------|---------------|------------------------------------------------------------------------------------------------------------|
| 1. Brute Force | T1110<br>Brute Force | HIGH (85/100) | High Confidence: 17 failed authentication logins for admin from 192.168.1.44 followed by successful login. |

|                          |                            |                 |                                                                                                                    |
|--------------------------|----------------------------|-----------------|--------------------------------------------------------------------------------------------------------------------|
| 2. Suspicious PowerShell | T1059.001<br>PowerShell    | HIGH (90/100)   | High Confidence: powershell.exe spawned by Word macro (winword.exe) with Base64 payload & DownloadString.          |
| 3. Port Scanning         | T1046<br>Network Discovery | MEDIUM (65/100) | Medium Confidence: Origin IP 192.168.1.105 connecting to 25 distinct destination ports within 2 minutes.           |
| 4. Suspicious DNS        | T1071.004<br>DNS Tunneling | HIGH (80/100)   | Medium-High Confidence: Workstation hr-laptop-12 issuing 35 high-entropy DNS queries to exfil-data.c2-network.top. |
| 5. Impossible Travel     | T1078<br>Valid Accounts    | HIGH (85/100)   | High Confidence: User sarah.connor authenticating from USA, then 12 minutes later from Japan.                      |

## 5. Governance & Controls Module (/governance)

The Governance & Controls module is a real security-control layer with Role-Based Access Control (RBAC). It features live administrative configuration controls and persistent governance audit logging:

- **Role-Based Access Control (RBAC):** SOC Analysts operate in read-only policy view. Attempting to modify governance rules returns 403 Forbidden: SOC Admin permission required.
- **REST API Endpoints:** GET /api/governance, PUT /api/governance (verifies X-User-Role: admin), GET /api/governance/audit.
- **Governance Audit History:** All policy edits are recorded in GovernanceAuditModel with admin\_id, setting\_changed, old\_value, new\_value, and timestamp.

## 6. Automated Verification Test Suite

| Test Case                        | Expected Behavior                                                        | Result Status |
|----------------------------------|--------------------------------------------------------------------------|---------------|
| Health Check Endpoint            | Returns online status, connected SIEM adapter, and active Two-Gate mode. | [OK] PASS     |
| Garbage Input ('dfhj')           | Halted at Gate 1. Status: INTENT_BLOCKED. 0 SQL queries run.             | [OK] PASS     |
| General Non-Security ('weather') | Halted at Gate 1. Status: INTENT_BLOCKED. 0 SQL queries run.             | [OK] PASS     |
| RBAC 403 Forbidden Test          | Analyst PUT /api/governance fails with 403 Forbidden.                    | [OK] PASS     |
| Governance 24h Cap Enforcement   | 7-day query under 24h policy rejected at Gate 2 with 0 rows returned.    | [OK] PASS     |

|                             |                                                                            |           |
|-----------------------------|----------------------------------------------------------------------------|-----------|
| Brute Force Query Execution | Passed Gate 1 and Gate 2. Returns live log evidence & MITRE T1110 mapping. | [OK] PASS |
|-----------------------------|----------------------------------------------------------------------------|-----------|

**CyberQuery AI System Verification:** 100% Fully Verified & Operational

**Frontend Web App:** <http://localhost:3000> | **FastAPI Engine:** <http://localhost:8000>